

ADA CASA AL1 Security Assessment Package

Sonave Cloud Application Security Verification (48-Control OWASP ASVS v4.0.3 Alignment)

EVALUATION EVIDENCE

Application Name: Sonave

Production Endpoint: <https://usesonave.com>

Primary Contact: Derek Gallardo (derekgallardo01@gmail.com)

Assessment Tier: CASA AL1 (Formerly Tier 2)

Assessor / Lab: TAC Security (ESOF AppSec ADA CASA)

Invoice / Ref ID: TAC-10788

Requested Google Scopes: <https://www.googleapis.com/auth/meetings.space.readonly>,
<https://www.googleapis.com/auth/meetings.conference.media.readonly>

Section 1: Complete 48-Control CASA AL1 SAQ Verification Matrix

ID	Domain	Requirement Summary	Status	Implementation Details & Evidence
1.1.1	Authentication	Brute force attack resistance	Compliant	Sliding-window IP rate limiter on /auth/* (20 req/60s max per IP, returns HTTP 429).
1.1.2	Authentication	Secure random initial passwords	Compliant / N/A	Authentication is delegated to Google OAuth 2.0. No local password generation.
1.1.3	Authentication	Offline resistant password storage	Compliant / N/A	Zero password storage. Authentication relies on Google OAuth 2.0 OpenID Connect.
1.2.1	Authentication	No default credentials on public interfaces	Compliant	No default administrative or maintenance credentials exist.
1.3.1	Authentication	Out-of-band verifier expiration	Compliant	OAuth state anti-CSRF cookies enforce a 10-minute finite TTL.
1.3.2	Authentication	Out-of-band verifier single use	Compliant	OAuth state cookie is deleted immediately upon callback verification.
1.3.3	Authentication	Out-of-band verifier securely random	Compliant	Cryptographically secure nonces generated via Python <code>secrets.token_urlsafe(32)</code> .
1.3.4	Authentication	Out-of-band verifier brute force resistance	Compliant	256-bit cryptographic entropy prevents online/offline brute-force verification.
2.1.1	Session Mgmt	No tokens/secrets in URL query parameters	Compliant	Session tokens transmitted exclusively via HTTP-only cookies and Authorization headers.
2.2.1	Session Mgmt	Logout invalidates session & refresh tokens	Compliant	POST /auth/logout increments server-side session version and revokes tokens at Google.
2.2.2	Session Mgmt	Terminate all active sessions on password change	Compliant	Atomic session version bumping in database revokes all issued tokens instantly.
2.2.3	Session Mgmt	Stateless tokens expire within 24 hours	Compliant	Session tokens enforce finite TTL and server-side version verification.
2.3.1	Session Mgmt	Cookie Secure attribute set	Compliant	All cookies explicitly set Secure=True (HTTPS only).
2.3.2	Session Mgmt	Cookie HttpOnly attribute set	Compliant	All cookies explicitly set HttpOnly=True (inaccessible to JavaScript).
2.3.3	Session Mgmt	Session tokens used over static API keys	Compliant	Dynamic HMAC-SHA256 signed session tokens minted per authenticated session.
2.3.4	Session Mgmt	Stateless tokens use digital signatures	Compliant	HMAC-SHA256 digital signature prevents tampering, enveloping, and null cipher attacks.

ID	Domain	Requirement Summary	Status	Implementation Details & Evidence
2.4.1	Session Mgmt	Valid session required for sensitive actions	Compliant	All API endpoints enforce <code>Depends(require_principal) / Depends(require_auth)</code> .
3.1.1	Access Control	Least privilege on trusted service layer	Compliant	Role-based access control (member, admin) enforced in backend service layer.
3.1.2	Access Control	Access attributes tamper-resistant	Compliant	User roles decoded from verified cryptographic session tokens; cannot be manipulated by users.
3.1.3	Access Control	Access controls fail securely	Compliant	Default-deny policy; unhandled exceptions or missing credentials return 401/403.
3.1.4	Access Control	IDOR protection on all records	Compliant	All database queries and file access strictly scoped to authenticated <code>user_id</code> .
3.1.5	Access Control	Anti-CSRF mechanism enforced	Compliant	Cookies set <code>SameSite=Lax</code> ; OAuth flow validates cryptographic HMAC state nonces.
3.1.6	Access Control	Directory browsing disabled	Compliant	Directory listing disabled on application server and Cloudflare Edge.
3.2.1	Access Control	Secure OAuth 2.0 Authorization Code Flow only	Compliant	Strict Authorization Code flow with server-side token exchange; no implicit flows.
3.2.2	Access Control	Validate <code>redirect_uri</code> and state	Compliant	Exact redirect URI matching in Google Console and HMAC verification of state.
3.3.1	Access Control	Admin Multi-Factor Authentication (MFA)	Compliant	Admin accounts use Google Workspace with enforced 2-Step Verification (2SV / FIDO2).
4.1.1	Communications	Enforce TLS 1.2+ and secure cipher suites	Compliant	TLS 1.3 enforced via Cloudflare Edge with HSTS preload enabled (1 year max-age).
4.1.2	Communications	Trusted TLS certificates from trusted CAs	Compliant	Valid trusted Cloudflare / Let's Encrypt CA certificate.
4.1.3	Communications	No weak cryptography	Compliant	SHA-256, HMAC-SHA256, and AES-256 only. No MD5, SHA-1, or DES.
4.1.4	Communications	Cryptographic modules fail securely	Compliant	Constant-time <code>secrets.compare_digest</code> prevents timing attacks; safe exception handling.
5.1.1	Data Validation	Protect against HTTP parameter pollution	Compliant	Strict Pydantic schema validation and typing on all incoming JSON/query parameters.
5.1.2	Data Validation	URL redirects limited to allowlisted URLs	Compliant	Redirects restricted to relative paths (<code>/console</code>) and Google OAuth domains.
5.1.3	Data Validation	Avoid <code>eval()</code> or dynamic code execution	Compliant	Zero <code>eval()</code> , <code>exec()</code> , or dynamic execution on untrusted user data.
5.1.4	Data Validation	Protect against template injection	Compliant	Context-safe escaping and static templates.
5.1.5	Data Validation	Prevent Server-Side Request Forgery (SSRF)	Compliant	Outbound requests whitelisted to Google APIs and authorized meeting platforms (<code>ALLOWED_MEET_HOSTS</code>).
5.1.6	Data Validation	Protect against XPath / XML injection	Compliant	No XML or XPath parsing on untrusted user data.
5.1.7	Data Validation	Context-aware output escaping (XSS prevention)	Compliant	Strict Content-Security-Policy (CSP) and context-aware escaping on all rendered views.
5.1.8	Data Validation	Protect against SQL injection	Compliant	Parameterized SQLite queries (<code>?</code> placeholders) + column whitelist in <code>db.mark_bot()</code> .

ID	Domain	Requirement Summary	Status	Implementation Details & Evidence
5.1.9	Data Validation	Protect against OS command injection	Compliant	No system shell invocation on user-supplied parameters.
5.1.10	Data Validation	Protect against LFI / RFI attacks	Compliant	Regex path sanitization [^A-Za-z0-9_-]+ and strict traversal rejection.
5.2.1	Data Validation	Protect against malicious file uploads	Compliant	Uploads restricted to PCM/WAV audio; no execution permissions in storage volumes.
6.1.1	Configuration	Components free of known vulnerabilities	Compliant	pip-audit verified: 0 known CVEs across all production dependencies.
6.2.1	Configuration	Disable debug modes in production	Compliant	/docs, /redoc, and /openapi.json disabled in production.
6.3.1	Configuration	Origin header not used for auth decisions	Compliant	Authentication requires valid cryptographic session cookie/bearer token.
6.4.1	Configuration	Protection against subdomain takeover	Compliant	DNS records managed directly on Cloudflare with zero dangling CNAME records.
6.5.1	Configuration	No logging of credentials or payment details	Compliant	Credentials, OAuth secrets, voiceprints, and PII stripped from logs.
6.6.1	Configuration	Browser storage cleared on logout	Compliant	Session cookies deleted and expired on POST /auth/logout.
6.7.1	Configuration	Secure storage of tokens & server secrets	Compliant	Secrets injected via Railway Environment Variables; tokens stored on encrypted volume.

Section 2: System Architecture & Privacy Boundary

Sonave is an AI voice authenticity and deepfake detection engine protecting Google Meet conference calls. The production application is hosted on Railway's containerized infrastructure fronted by Cloudflare CDN with strict TLS 1.3 encryption.

Data Protection & Privacy Boundary:

- **Zero Third-Party Training:** User meeting audio and voiceprints are never transmitted to third parties or used to train external foundation models.
- **Data Minimization:** Only requested media frames during active monitored meetings are processed.
- **Ephemeral Buffering:** Audio buffers are scored in-memory and discarded unless the workspace owner requests archiving.
- **Encrypted Volume Storage:** Persistent data resides on isolated Railway /data encrypted storage volumes.

Section 3: Dependency Vulnerability Audit (pip-audit)

```
{
  "dependencies_scanned": 19,
  "vulnerabilities_found": 0,
  "status": "PASSED (0 Known CVEs)",
  "advisory_database": "PyPI Advisory DB & OSV",
  "audit_timestamp": "2026-09-02T20:30:00Z"
}
```

Section 4: Live HTTP Security Headers Verification

```
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
X-Frame-Options: SAMEORIGIN (ALLOW-FROM meet.google.com for addon)
X-Content-Type-Options: nosniff
```

```
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: microphone=(self), camera=(), geolocation=(), payment=()
Cross-Origin-Opener-Policy: same-origin-allow-popups
Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline' https://accounts.google.com
https://cdn.jsdelivr.net; ...
Cache-Control: no-store, no-cache, must-revalidate, private (on /console, /api/*, /auth/*)
Server Info: Removed (X-Powered-By header stripped; /docs & /redoc disabled)
```